Lab 1220: Secure Agentic AI with Role Based Access Control (RBAC), Context , and OBO in watsonx Orchestrate using Bob

Hands-on lab guide

Arvind Rajpurohit
Instructor

Lab authors: Ela Dixit, Madan S and Sindhoor Bhagwat

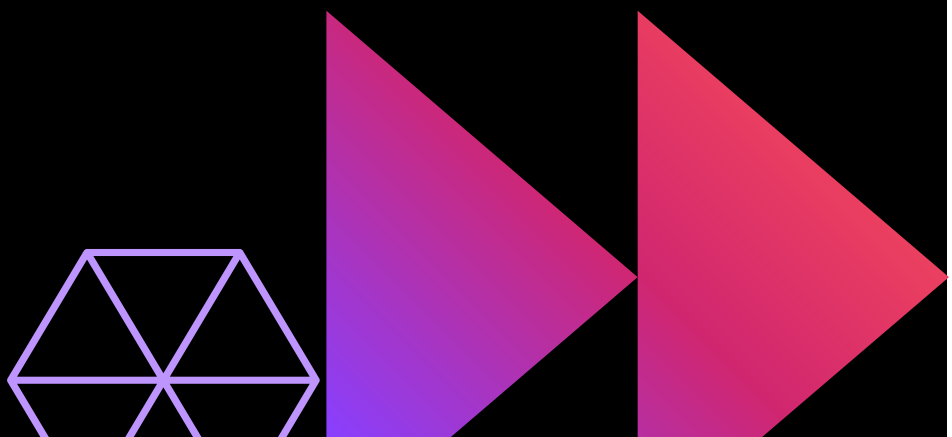


Table of Contents

1 Introduction 5

2 Architecture 5

2.1 Authentication and OBO Flow 7

2.2 About this hands-on lab 7

3 Getting Started 7

3.1 Task 1 : Code Setup 8

3.2 Task 2 : Login to watsonx Orchestrate 10

3.3 Task 3 : Integrate IBM Bob to watsonx Orchestrate 13

4 Configure MCP Server in watsonx Orchestrate 13

4.1 Task 4 : Create connections to access MCP Server 14

5 Agent Deploy & Security - Bob guided Tasks 14

5.1 Task 5 : Build and Deploy Agents 15

5.2 Task 6 : Import RBAC plugin and configure webchat 16

5.3 Task 7 : Enable security 17

5.4 Task 8 : Running the Web Application 18

6 Testing the Agents 19

6.1 Task 9: Validate role-based access 19

7 Lab Reference Materials (for instructor) 21

Notices and disclaimers

© 2026 International Business Machines Corporation. No part of this document may be reproduced or transmitted in any form without written permission from IBM.
U.S. Government Users Restricted Rights — use, duplication or disclosure restricted by GSA ADP Schedule Contract with IBM.

This document is current as of the initial date of publication and may be changed by IBM at any time. Not all offerings are available in every country in which IBM operates.

Information in these presentations (including information relating to products that have not yet been announced by IBM) has been reviewed for accuracy as of the date of initial publication and could include unintentional technical or typographical errors. IBM shall have no responsibility to update this information.

This document is distributed “as is” without any warranty, either express or implied. In no event, shall IBM be liable for any damage arising from the use of this information, including but not limited to, loss of data, business interruption, loss of profit or loss of opportunity. IBM products and services are warranted per the terms and conditions of the agreements under which they are provided. The performance data and client examples cited are presented for illustrative purposes only. Actual performance results may vary depending on specific configurations and operating conditions. IBM products are manufactured from new parts or new and used parts.

In some cases, a product may not be new and may have been previously installed. Regardless, our warranty terms apply.”

Any statements regarding IBM's future direction, intent or product plans are subject to change or withdrawal without notice.

Performance data contained herein was generally obtained in a controlled, isolated environments. Customer examples are presented as illustrations of how those customers have used IBM products and the results they may have achieved. Actual performance, cost, savings or other results in other operating environments may vary.

References in this document to IBM products, programs, or services does not imply that IBM intends to make such products, programs or services available in all countries in which IBM operates or does business.

Workshops, sessions and associated materials may have been prepared by independent session speakers, and do not necessarily reflect the views of IBM. All materials and discussions are provided for informational purposes only, and are neither intended to, nor shall constitute legal or other guidance or advice to any individual participant or their specific situation.

It is the customer’s responsibility to ensure its own compliance with legal requirements and to obtain advice of competent legal counsel as to the identification and interpretation of any relevant laws and regulatory requirements that may affect the customer’s business and any actions the customer may need to take to comply with such laws. IBM does not provide legal advice or represent or warrant that its services or products will ensure that the customer follows any law.

Notices and disclaimers (Continued)

Questions on the capabilities of non-IBM products should be addressed to the suppliers of those products. IBM does not warrant the quality of any third-party products, or the ability of any such third-party products to interoperate with IBM's products. IBM expressly disclaims all warranties, expressed or implied, including but not limited to, the implied warranties of merchantability and fitness for a purpose.

The provision of the information contained herein is not intended to, and does not, grant any right or license under any IBM patents, copyrights, trademarks or other intellectual property right.

IBM, the IBM logo, and ibm.com are trademarks of International Business Machines Corporation, registered in many jurisdictions worldwide. Other product and service names might be trademarks of IBM or other companies. A current list of IBM trademarks is available on the Web at "Copyright and trademark information" at: www.ibm.com/legal/copytrade.shtml.

1 Introduction

As AI moves from answering questions to taking action on behalf of users, enterprise AI systems need more than intelligence-they need controlled, role-aware access to enterprise data and tools. An HR assistant, for example, may need to provide leave balances and office information to every employee, while access to sensitive information such as employee salaries and team dashboards should be restricted to authorized managers.

In this lab, you will build an enterprise-style, secure multi-agent HR assistant using IBM Bob and watsonx Orchestrate. Starting with natural-language prompts as your specification, you will turn the design into a working agentic AI application with role-based access and secure access to external HR tools.

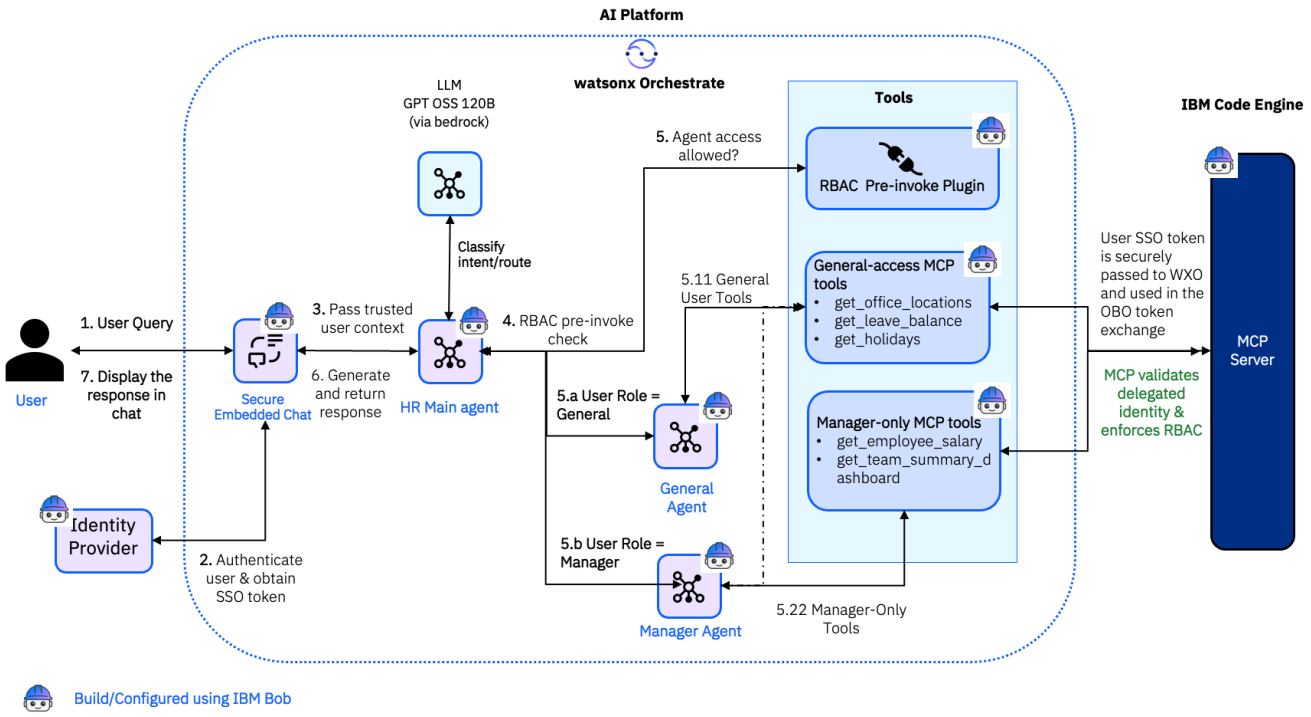
You will:

- Configure MCP servers and HR tools that provide employee and organizational information.
- Build three AI agents-a General Agent, Manager Agent, and HR Main Agent that orchestrates the overall experience.
- Deploy and analyze the agents in watsonx Orchestrate.
- Secure the embedded chat in a custom web application using Identity Provider authentication and SSO.
- Enforce role-based access control (RBAC) so that users can access only the agents and tools permitted for their role.
- Implement secure MCP access using the On-Behalf-Of (OBO) flow, allowing downstream tools to authorize requests in the context of the authenticated user.

The lab follows a specification-driven approach: you describe what you want to build using Bob prompts, generate the required agent and tool definitions, deploy them to watsonx Orchestrate, and connect them to a secured end-user experience.

2 Architecture

The architecture below illustrates how these components work together-from user authentication and agent orchestration to agent-level RBAC and MCP-level authorization-to deliver a secure, role-aware HR assistant.



1. The user interacts with the secure embedded watsonx Orchestrate chat in the custom web application and submits an HR-related query.
2. The Identity Provider (IdP) authenticates the user and enables Single Sign-On (SSO) for the web application. The user's SSO token is securely made available to the watsonx Orchestrate runtime through the embedded chat authentication flow.
3. The web application sends the user query and context variables to the HR Main Agent's runtime context. The HR Main Agent uses large language models (LLMs) to classify intent and identify the correct downstream agent or tool.
4. Before a downstream agent is invoked, the HR Main Agent executes the RBAC pre-invoke plug-in. The plug-in evaluates the user's role from the trusted context and determines whether the requested agent is allowed..
5. Role-based agent access:
    - General User: The General Agent is available and can access general-purpose MCP tools:
        - mcp_tools_server.get_office_locations — company office locations.
        - mcp_tools_server.get_leave_balance — leave balance for the logged-in employee.
        - mcp_tools_server.get_holidays — upcoming company holidays.
    - Manager: Both the General Agent and Manager Agent are available. In addition to the general-purpose tools, the Manager Agent can access restricted MCP tools:
        - mcp_tools_server.get_employee_salary — an employee's salary in USD.
        - mcp_tools_server.get_team_summary_dashboard — team dashboard metrics.
6. When an authorized agent invokes an MCP tool, the configured SSO/OBO connection provides delegated access on behalf of the authenticated user. The MCP Server validates the delegated user identity and enforces the required authorization before allowing the requested tool to execute.
7. This provides a second authorization boundary at the tool level, ensuring that access to sensitive HR capabilities is not based solely on the agent-level RBAC decision.

8. The result from the authorized tool is returned to the downstream agent and then to the HR Main Agent. The HR Main Agent processes the result, generates the final response, and returns it to the user through the secure embedded chat.

2.1 Authentication and OBO Flow

The Identity Provider (IdP) is responsible for authenticating users and providing SSO for the custom web application. The authenticated user's SSO token is securely passed through the embedded chat authentication flow to the watsonx Orchestrate runtime.

For MCP access, the solution uses the On-Behalf-Of (OBO) flow. When an agent invokes an MCP tool, the configured connection uses the user's SSO token in the OBO flow to obtain delegated authorization for the downstream MCP service. This allows the MCP Server to authenticate and authorize the request in the context of the authenticated user.

As a result, the MCP Server does not simply treat every request as coming from the AI application itself; it can apply the appropriate access policies based on the user's delegated identity.

2.2 About this hands-on lab

The objective of this hands-on lab is to build a secure, role-aware HR assistant in watsonx Orchestrate where agent and tool access is determined by the signed-in user's role. You will explore how agent orchestration, MCP tools, authentication, and role-based access control work together to create a secure enterprise AI experience.

In this lab, you will learn to:

1. **Build AI agents and MCP tools using IBM Bob**
   Use natural-language prompts to define the General Agent, Manager Agent, HR Main Agent, and supporting HR tools.
2. **Configure and secure the agentic AI solution in watsonx Orchestrate**
   Import, configure, and deploy the agents and MCP tools, and implement role-based access using an RBAC pre-invoke plug-in.
3. **Secure and embed the watsonx Orchestrate chat in a custom application**
   Configure authentication and SSO and obtain the embed code required to integrate the secure chat experience into a web application.
4. **Implement secure MCP access using the OBO flow**
   Enable downstream MCP tools to authenticate and authorize requests on behalf of the signed-in user.
5. **Test and validate role-based access**
   Verify that general users can access only permitted agents and tools, while managers can access additional restricted HR capabilities.

3 Getting Started

In this section you will prepare the pre-requisites for the lab, install dependencies and download the code. Each section is divided into an actionable task.

Pre-requisites: Create an IBMid

You will need an **IBMid** to access IBM Cloud and other IBM services used in this lab.

> If you already have an IBMid, do not create another one. Use your existing IBMid to sign in.

Create your IBMid

1. Go to the official IBMid registration page: Create an IBMid.
2. Enter your email address. This email address will become your IBMid.
3. Create a password.
4. Enter your first name and last name.
5. Select your country or region of residence and provide any other required information.
6. Select **Next**.
7. Check your email for a 7-digit verification code from IBM.
8. Enter the verification code and select **Create Account**.
9. Review the IBM account privacy information and select **Proceed** to complete the registration.

IBM requires a valid email address because it is used to verify your account and for account security and recovery.

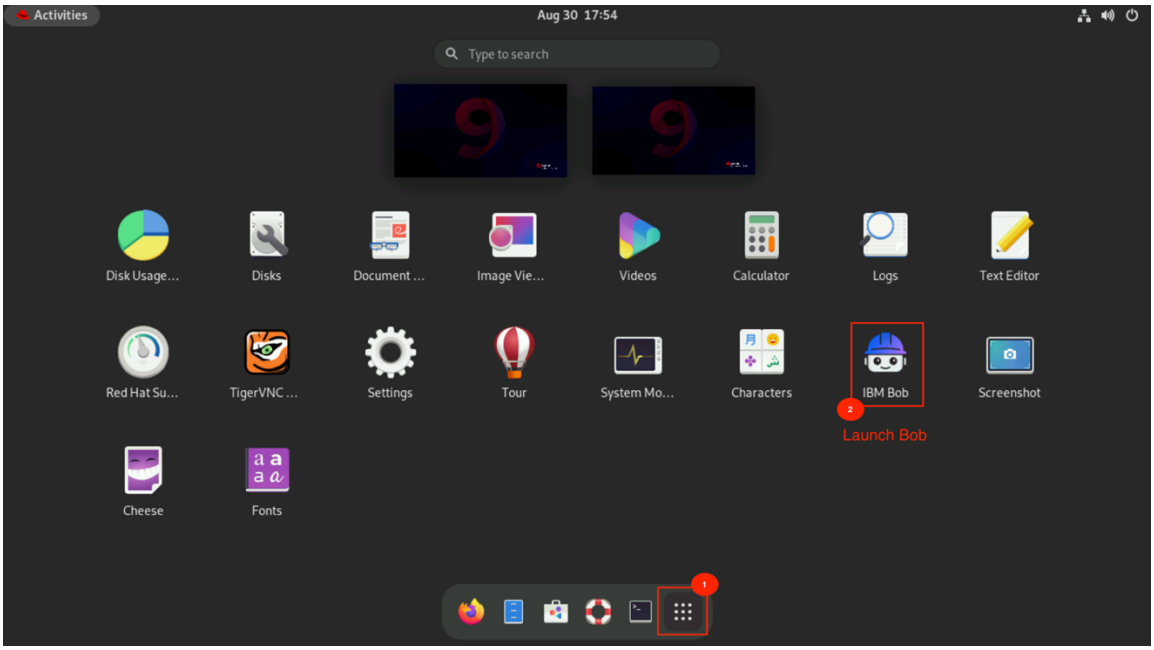
Before the lab

Please create and verify your IBMid **before the class begins**. This ensures that you can sign in to the required IBM services without using valuable lab time for account setup.

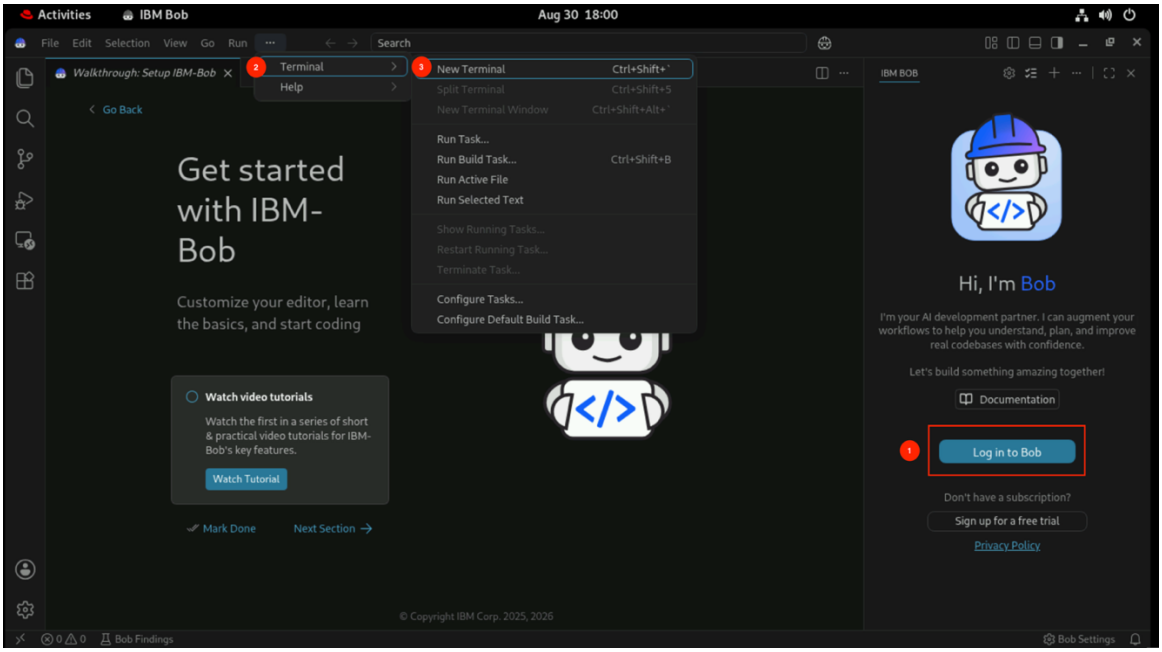
When the lab asks you to sign in, use the same email address and password you used when creating your IBMid.

3.1 Task 1 : Code Setup

1. Launch **IBM Bob**.



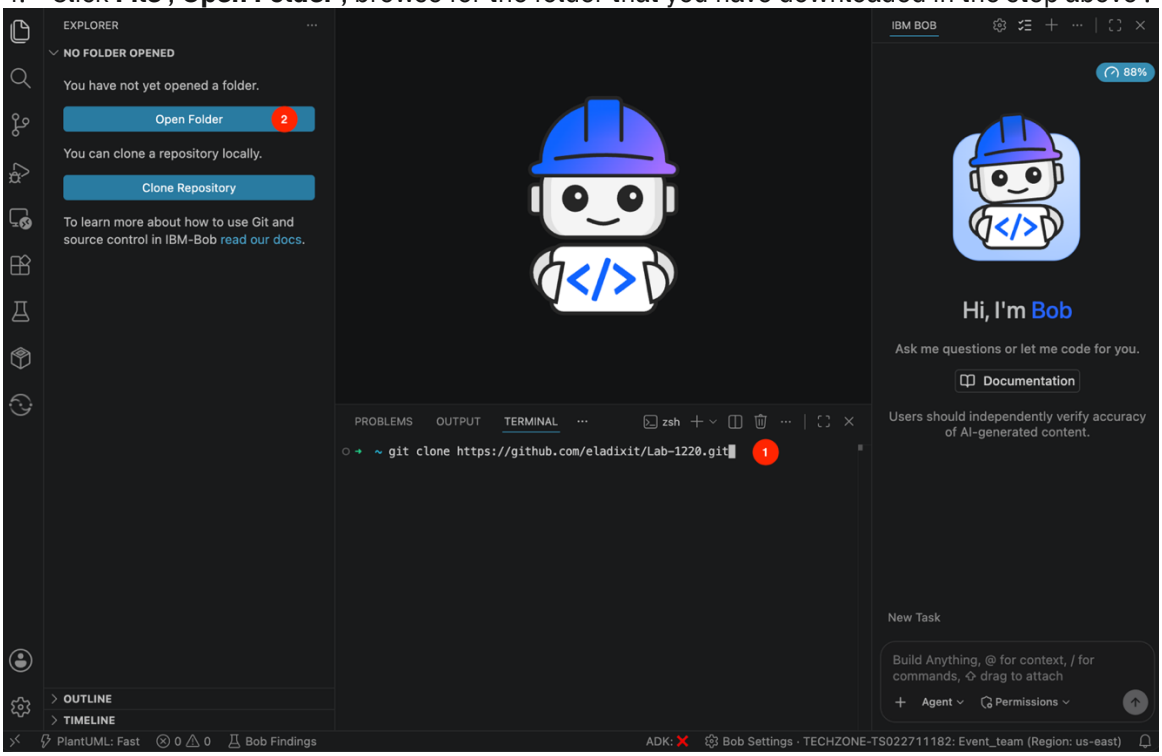
2. Login into Bob . Next Click à **Terminal** à **New Terminal**



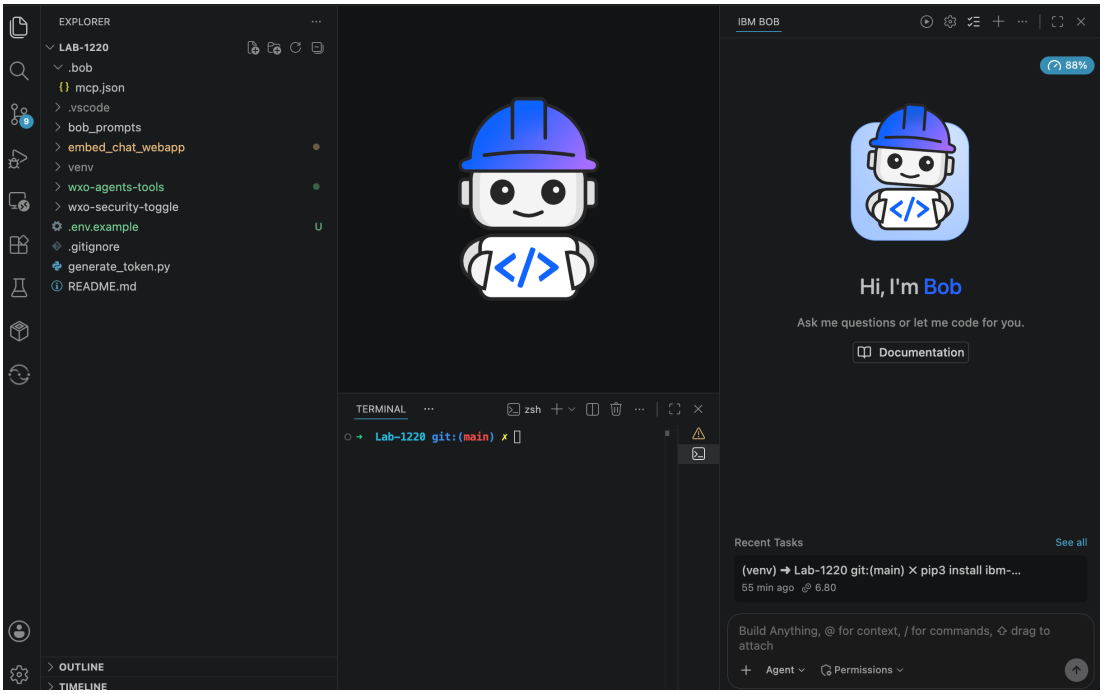
3. Clone the project to download the codebase **Lab-1220**.

   git clone https://github.com/arvindraj-lab/Lab-1220.git

4. Click **File** , **Open Folder** , browse for the folder that you have downloaded in the step above .

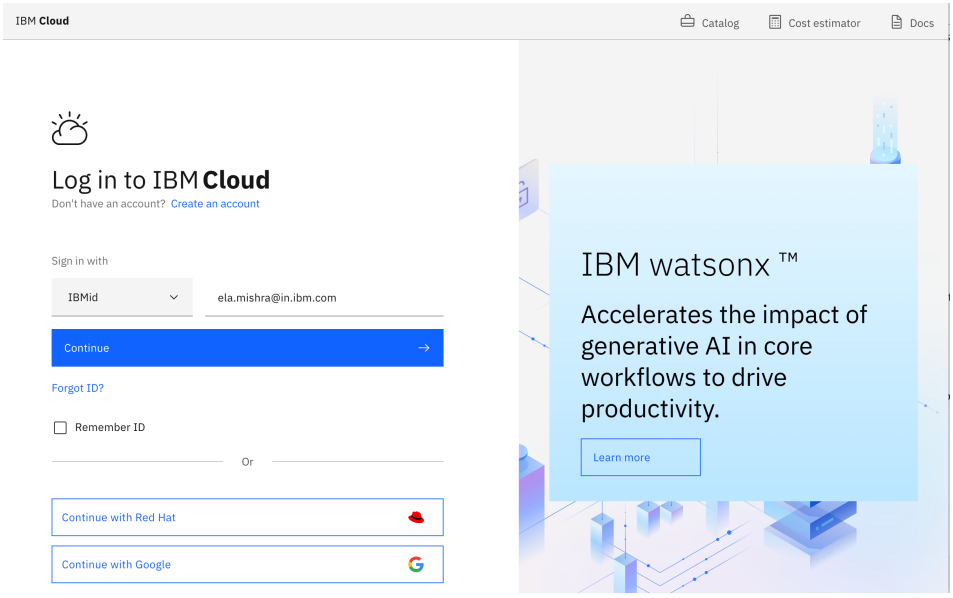


5. Open <**Lab 1220**> , ensure **.bob** folder is present , this is where **mcp** servers are pre-configured for you.

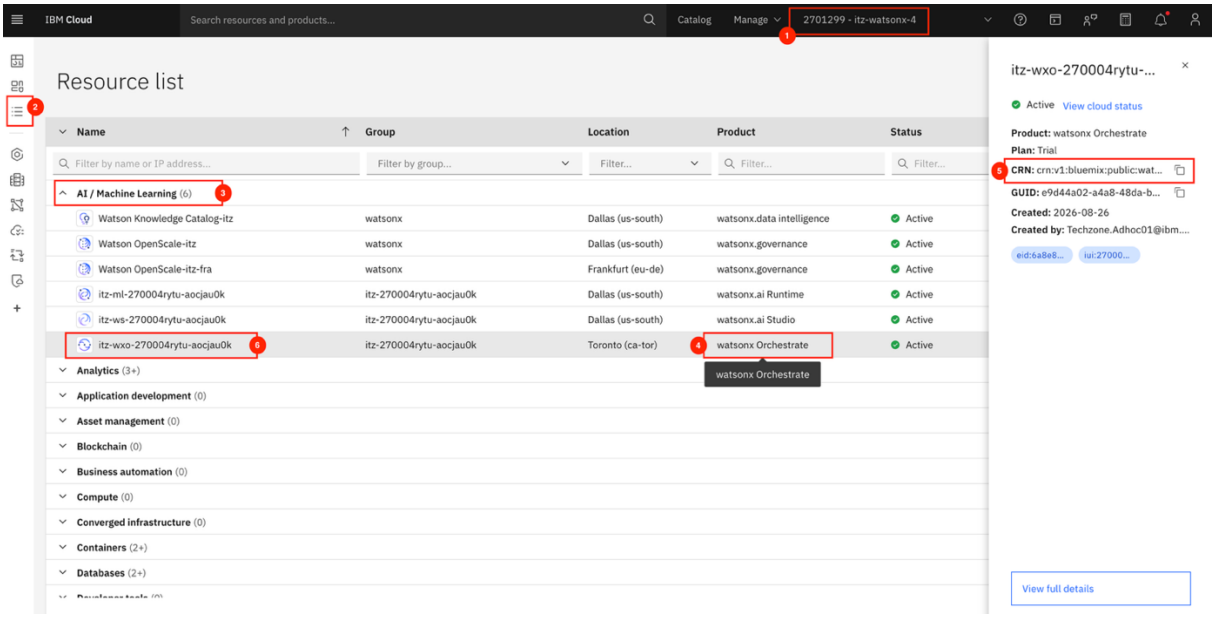


3.2 Task 2 : Login to watsonx Orchestrate

1. Log in to https://cloud.ibm.com using the participant credentials provided to you.

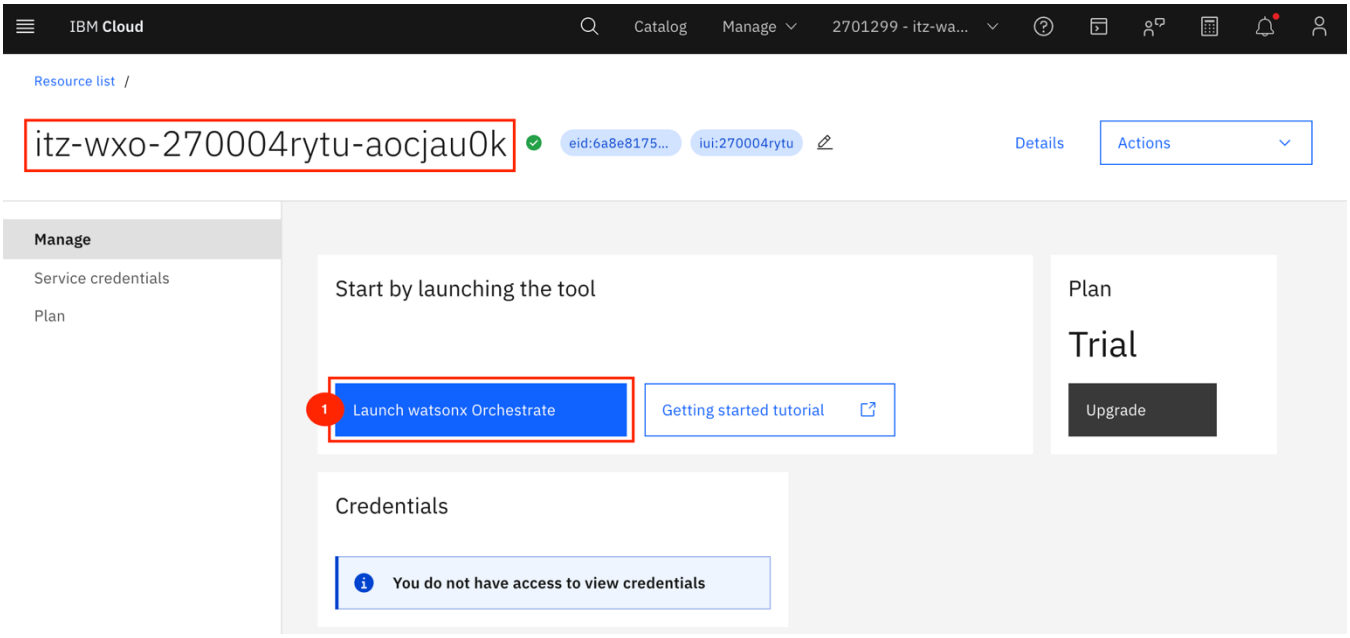


2. Ensure a **cloud account** (1) similar to the screenshot is selected for you .
3. Navigate to **Resources List** (2) -> AI/Machine Learning (3).
4. Click **watsonx orchestrate** (4) under product column. Copy the CRN value (5)

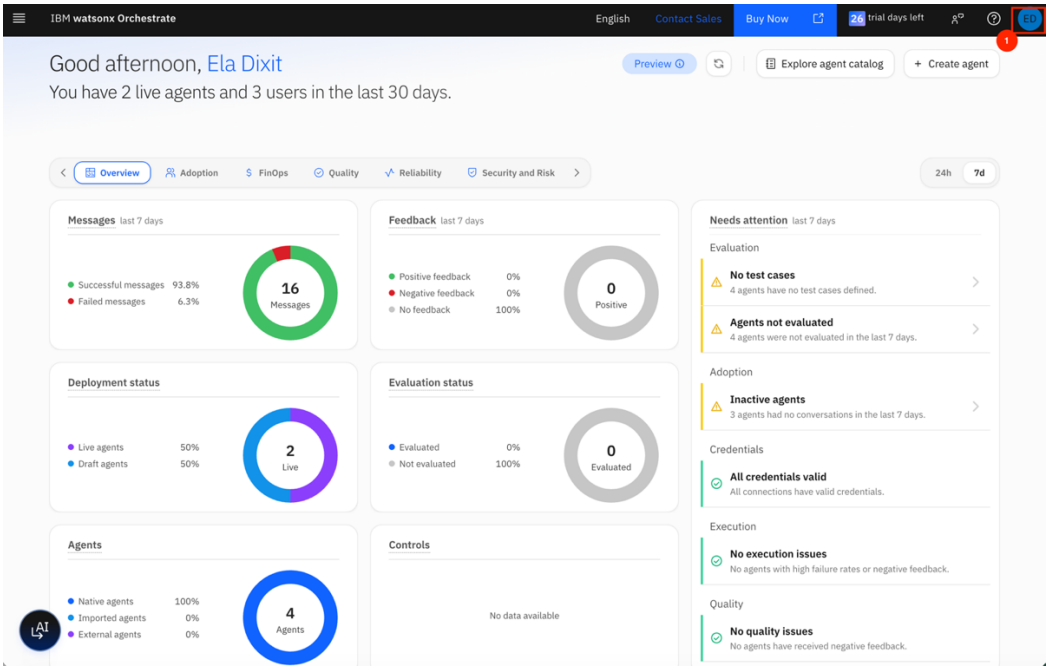


5. Click **itz-wxo-270004rytu-aocjau0k** 6 and launch it in a new tab.

   Note : This value “itz-wxo-270004rytu-aocjau0k“may be different for your environment .



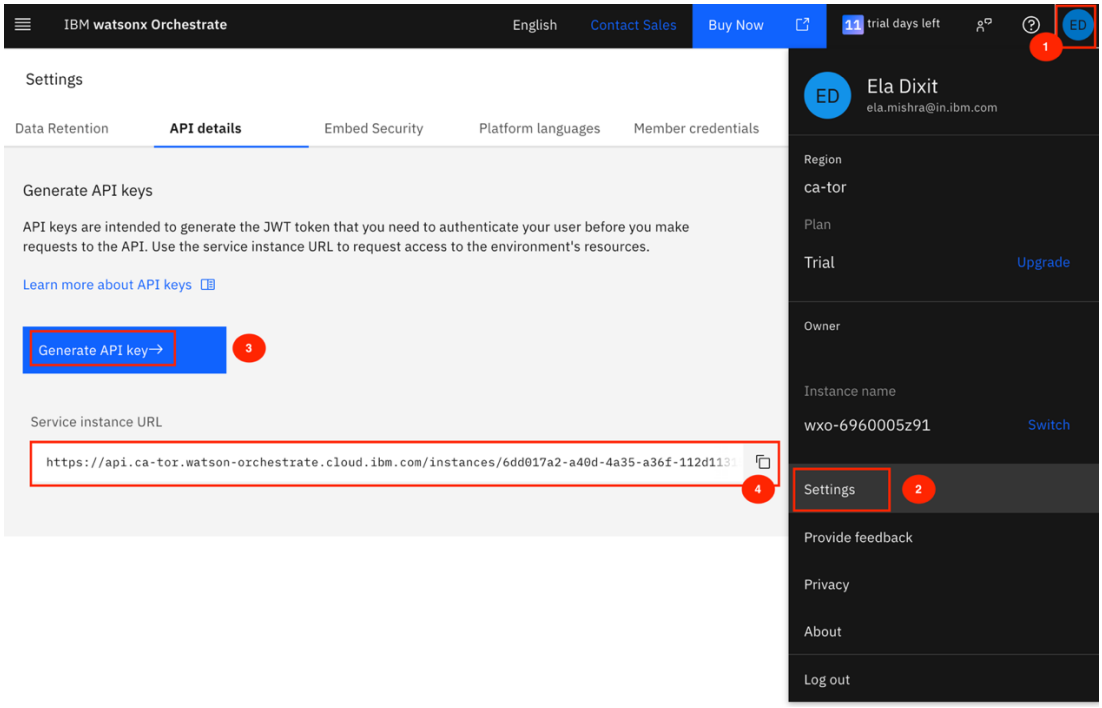
6. This is watsonx Orchestrate landing screen .



7. In the upper-right corner, click your **profile icon**, click **Settings** :

    a. Click **API details**.
    b. Click **Generate API key** to create the **IAM_API_KEY**. This will be visible only for the first time, so download and save it as well.
    c. Copy the **SERVICE_INSTANCE_URL**.

Note : You will use these values to connect to watsonx Orchestrate from IBM Bob.



3.3 Task 3 : Integrate IBM Bob to watsonx Orchestrate

1. In the Bob , open .env.example in Lab-1220 folder. Rename it to .env
2. Copy **CRN** , **SERVICE_INSTANCE_URL** and **IAM_API_KEY** from the previous step (Task 2) and update this file .
3. In the terminal, ensure **Lab-1220** is the current working directory .
4. Run the following commands in Bob terminal to install create a virtual environment and activate it .

   python3 -m venv venv

   source venv/bin/activate

   pip3 install ibm-watsonx-orchestrate==2.15.0

5. Replace the values <**SERVICE_INSTANCE_URL**> and <**IAM_API_KEY**> in the command below to integrate Bob with watsonx Orchestrate environment.

   orchestrate env add --name oic_dev --url <SERVICE_INSTANCE_URL>

   orchestrate env activate oic_dev --api-key <IAM_API_KEY>

4 Configure MCP Server in watsonx Orchestrate

Import the MCP toolkit and create a secure end-to-end connection from the embedded chat to the MCP tools using the On-Behalf-Of (OBO) flow. The MCP toolkit includes the following tools:

4.1 Task 4 : Create connections to access MCP Server

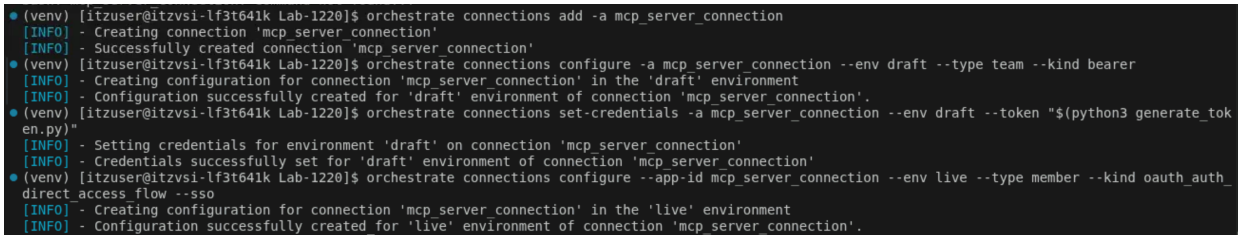
1. Run the commands in terminal to create connection

```
# 1. Add connection
orchestrate connections add -a mcp_server_connection

# 2. Configure draft environment
orchestrate connections configure -a mcp_server_connection --env draft --type team --kind bearer

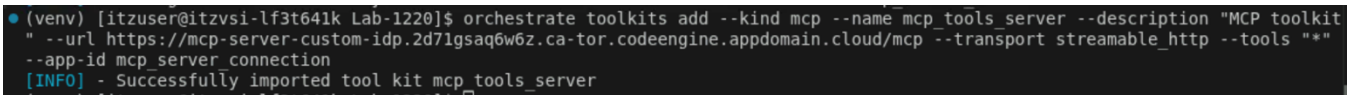
# 3. Set draft credentials using generated token
orchestrate connections set-credentials -a mcp_server_connection --env draft --token "$(python3 generate_token.py)"

# 4. Configure live environment for SSO direct access flow
orchestrate connections configure --app-id mcp_server_connection --env live --type member --kind oauth_auth_direct_access_flow --sso
```



2. Run the command below. It already contains the lab's MCP server URL. This will import the MCP toolkit to the watsonx Orchestrate instance and provide access all the tools listed in the server :

orchestrate toolkits add --kind mcp --name mcp_tools_server --description "MCP toolkit" --url https://mcp-server-custom-idp.2d71gsaq6w6z.ca-tor.codeengine.appdomain.cloud/mcp --transport streamable_http --tools "*" --app-id mcp_server_connection



Now, you can see these tools in watsonx Orchestrate.

- mcp_tools_server.get_office_locations
- mcp_tools_server.get_leave_balance
- mcp_tools_server.get_holidays
- mcp_tools_server.get_employee_salary
- mcp_tools_server.get_team_summary_dashboard

5 Agent Deploy & Security - Bob guided Tasks

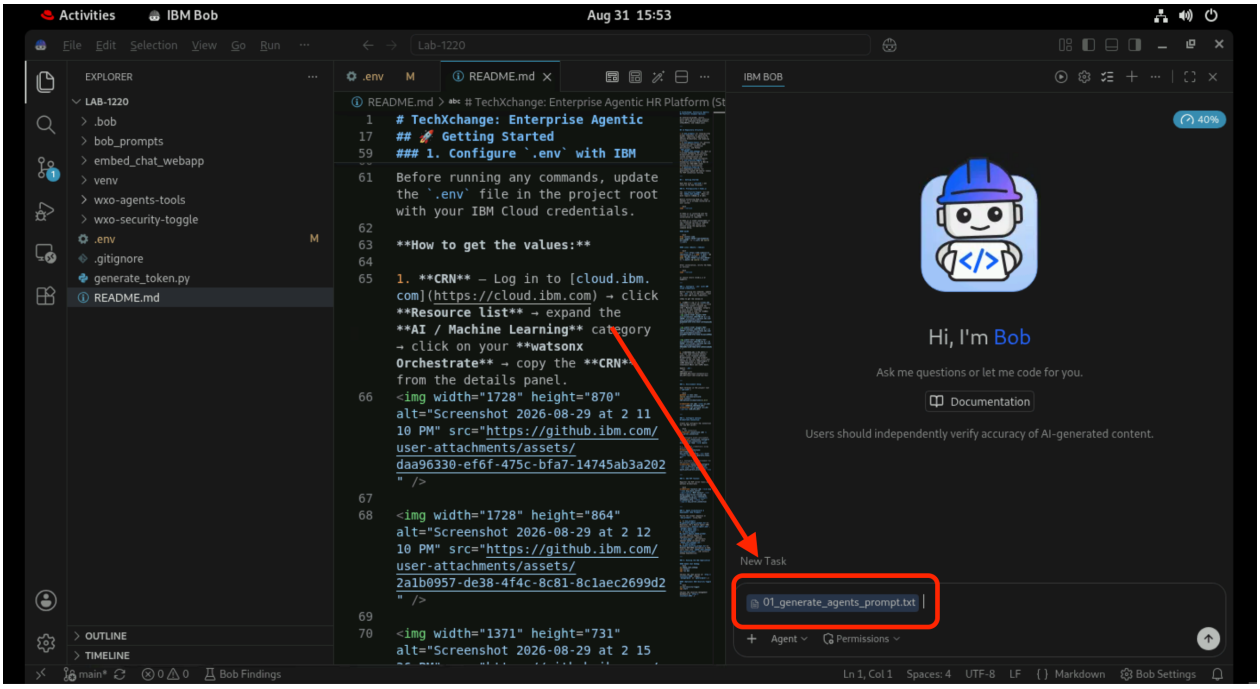
In this section, you will paste the prompts in IBM Bob to Build , Deploy Agents

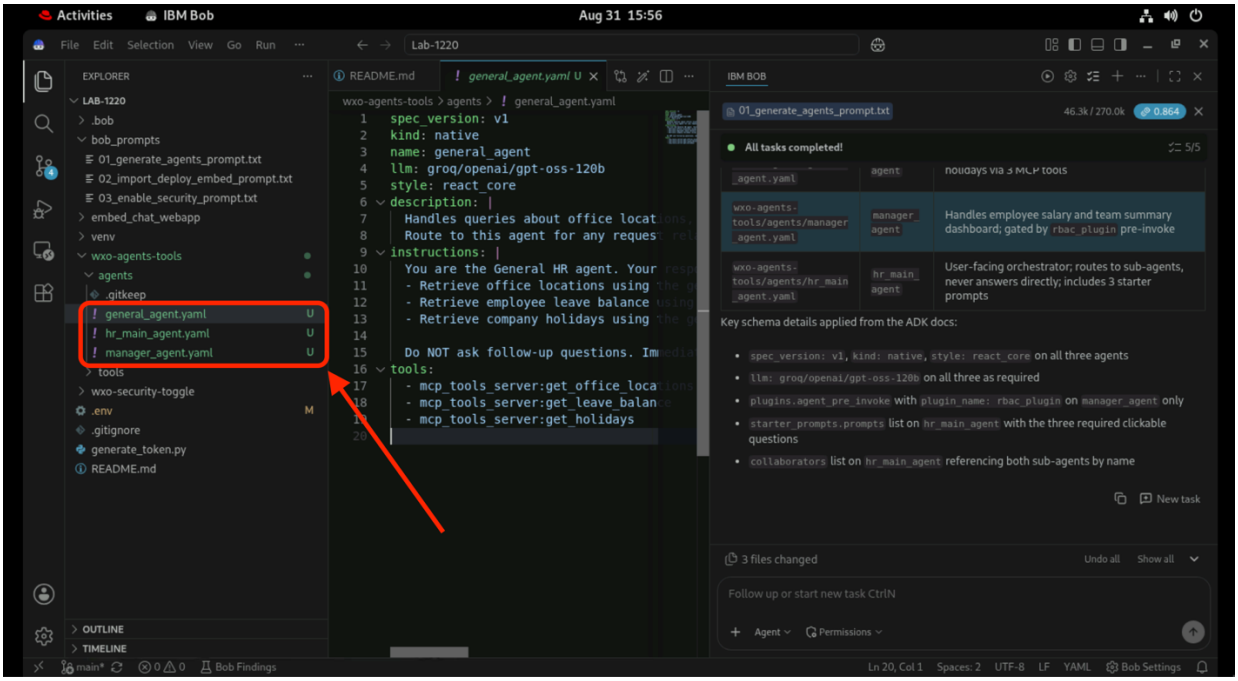
5.1 Task 5 : Build and Deploy Agents

1. Paste the exact prompt provided here in Bob chat , or simply write ***@01_generate_agents_prompt.txt in the Bob chat*** to create the agent specifications as yaml and it saves them in wxo-agents-tools/agents/ . Refer to the images below :

    a. general_agent.yaml
    b. manager_agent.yaml
    c. hr_main_agent.yaml

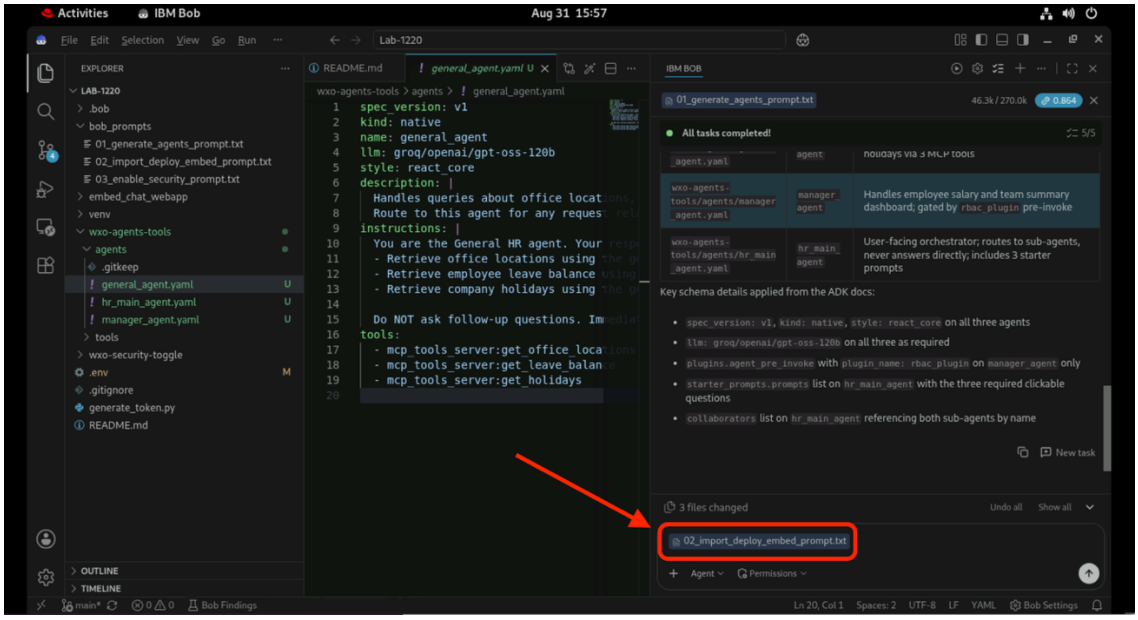
    Note : *Using @ is the shortcut to paste the contents of the file in the chat window*

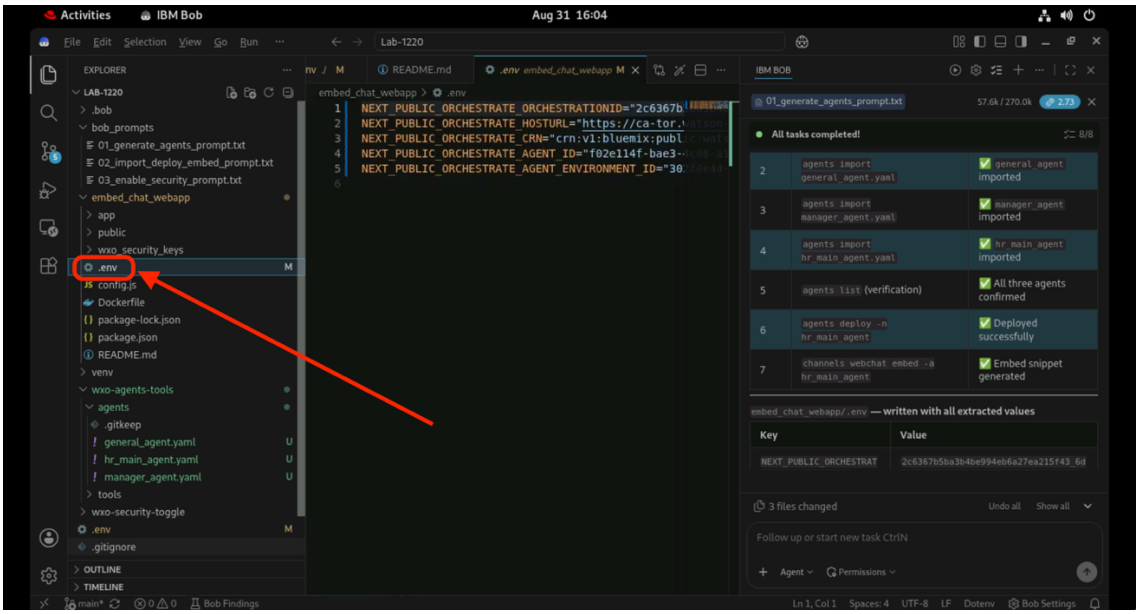




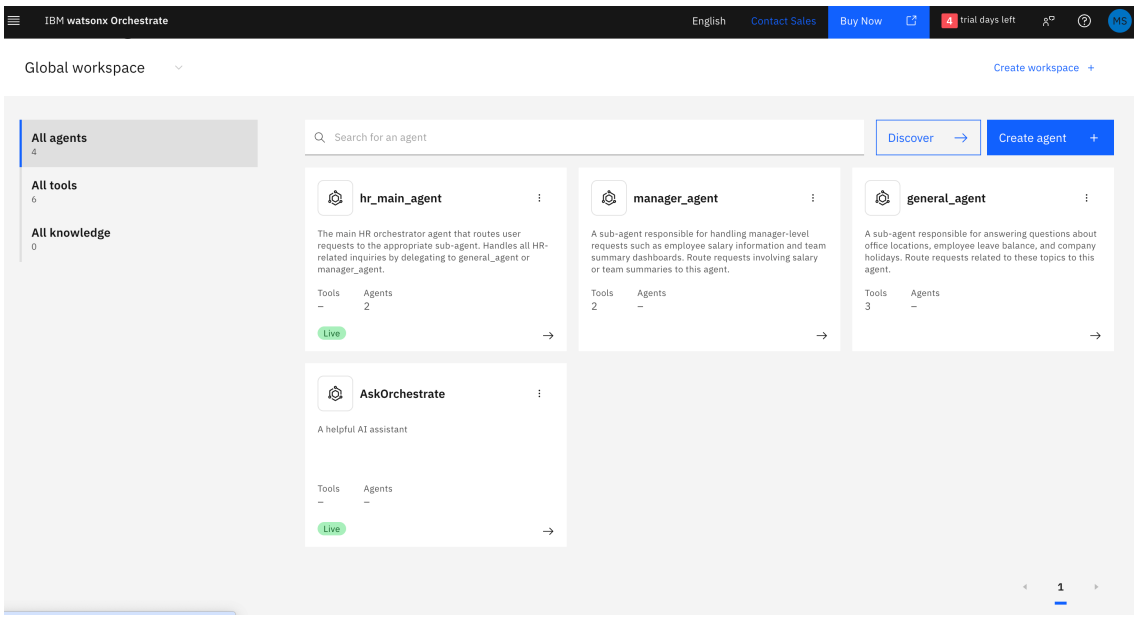
5.2 Task 6 : Import RBAC plugin and configure webchat

1. Paste the next prompt or simply write ***@02_import_deploy_embed_prompt.txt*** in the Bob chat. This will :
    a. Import the RBAC plugin tool and agents into watsonx Orchestrate.
    b. Deploy hr_main_agent
    c. Extracts webchat embed variables into embed_chat_webapp/.env





2. The agents are created successfully in watsonx Orchestrate

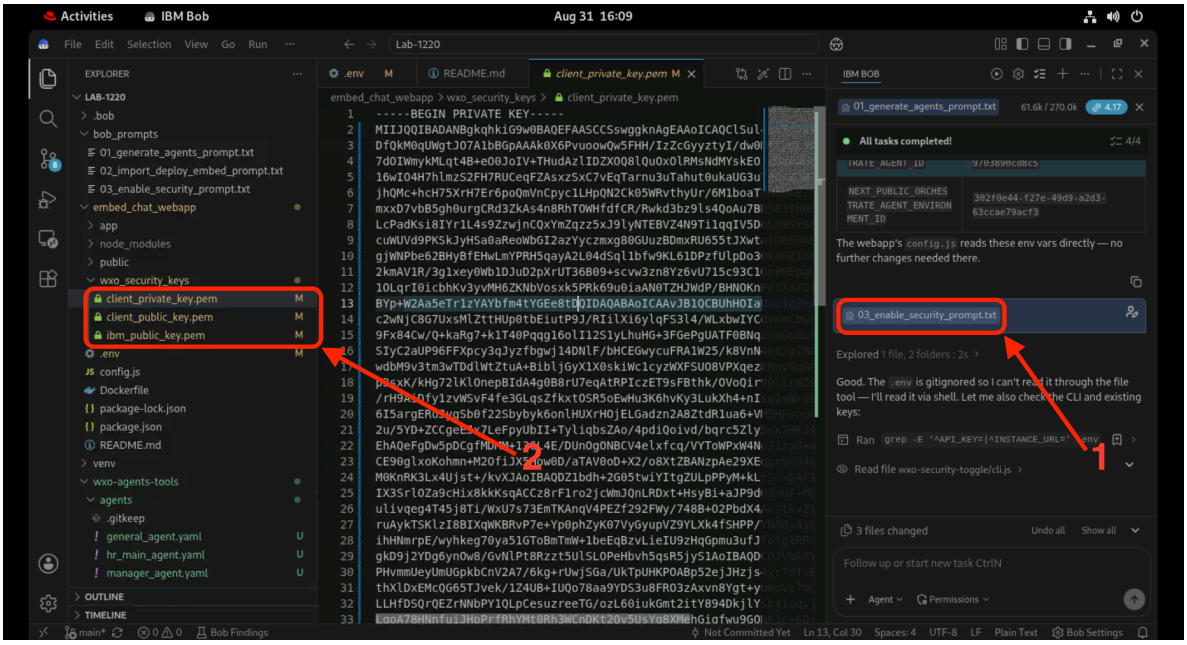


5.3 Task 7 : Enable security

1. Paste the next prompt or simply write **@03_enable_security_prompt.txt** in the Bob chat to enable security for the agents in the chat . This will

    a. Enable RSA-4096 encryption on watsonx orchestrate, syncs keys into embed_chat_webapp/wxo_security_keys/

b. Installs webapp dependencies.



5.4 Task 8 : Running the Web Application

1. Execute this command to start the web application .

```
cd embed_chat_webapp
npm install
npm run dev
```

```
(venv) madan@Madans-MacBook-Pro embed_chat_webapp % npm run dev

> embedchat-ui@1.0.0 dev
> next dev

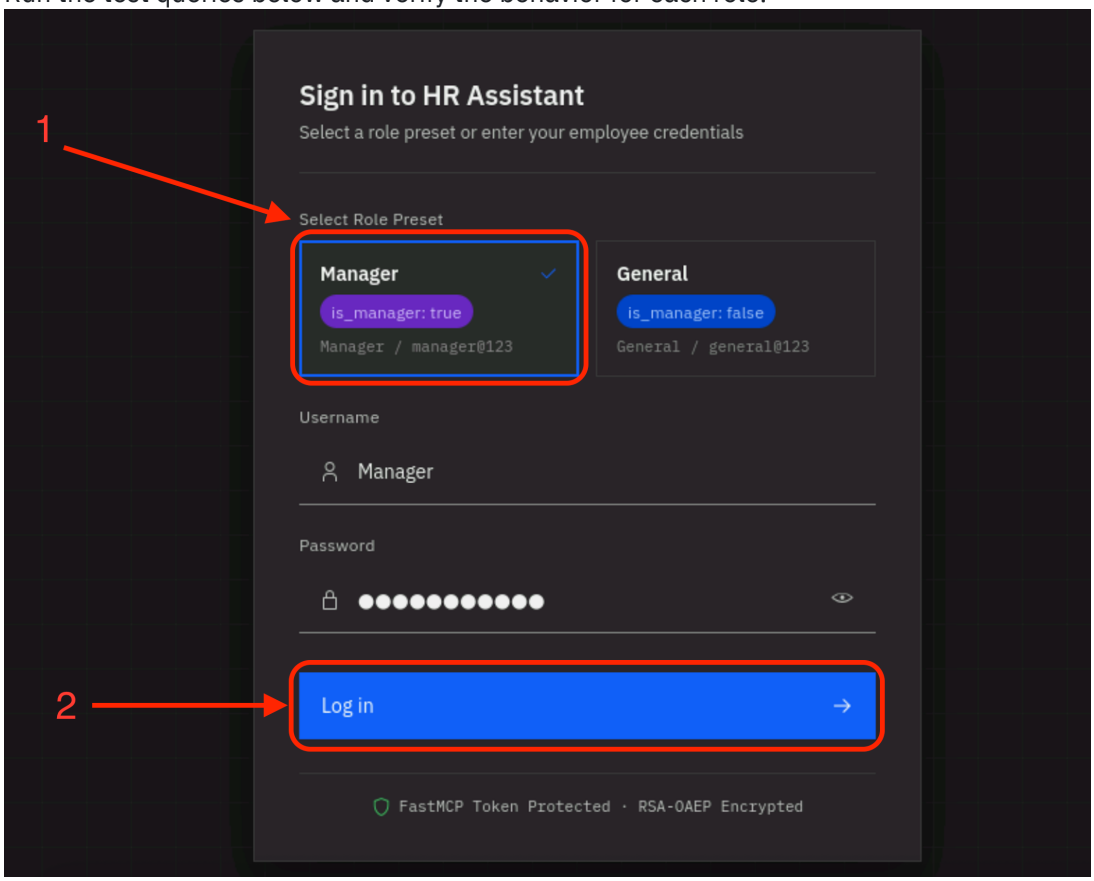
  ▲ Next.js 14.2.35
  - Local:        http://localhost:3000
  - Environments: .env

 ✓ Starting...
 ✓ Ready in 2s
 ○ Compiling / ...
```

6 Testing the Agents

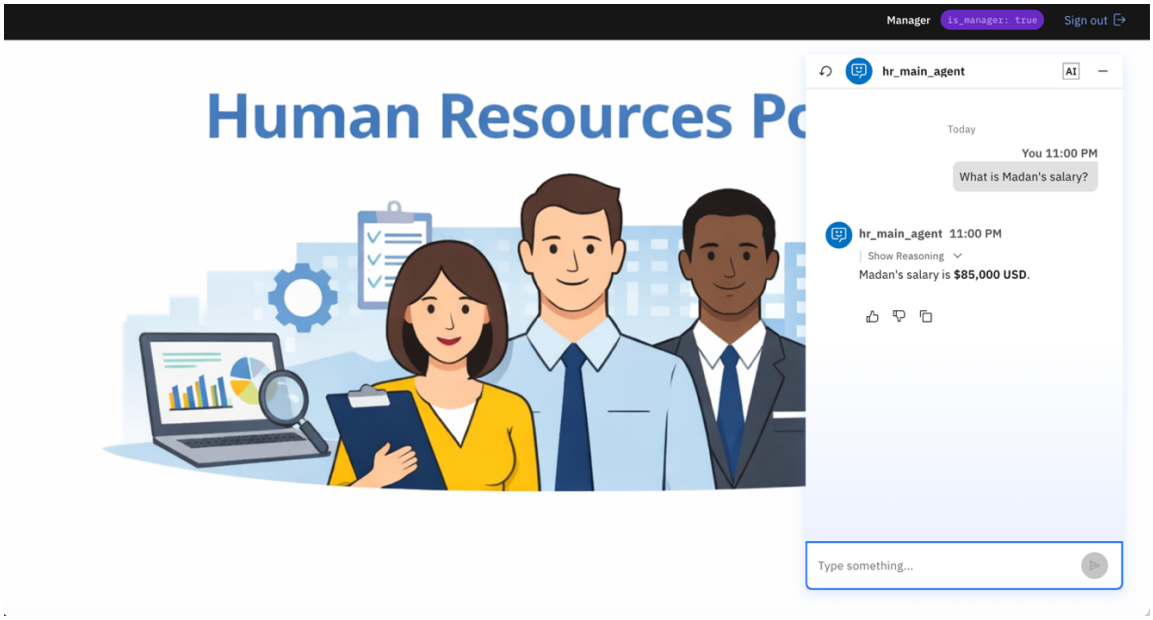
6.1 Task 9: Validate role-based access

1. Log in to the application as a user with a defined role (general user or manager).
2. Click the chat icon to open the embedded chat interface.
3. Run the test queries below and verify the behavior for each role.



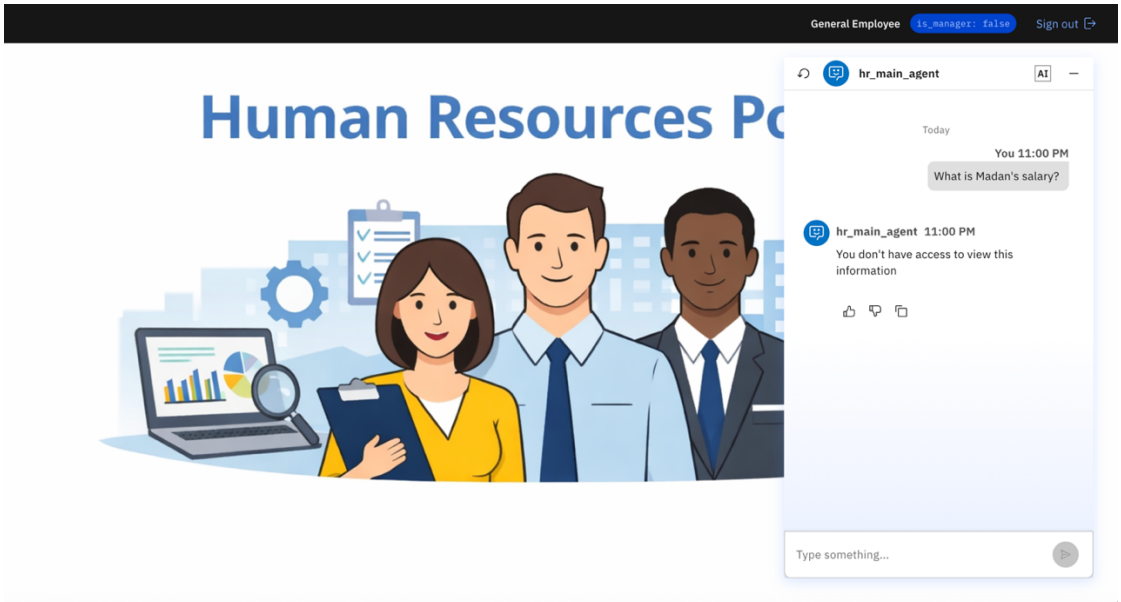
Case 1: Manager-level access

- User role: Manager
- Query: "What is Madan's salary?"
- Expected response: The agent retrieves and displays the salary because the user has manager-level authorization.



Case 2: General-user access (authorization failure)

- User role: General user
- Query: "What is Madan's salary?"
- Expected response: The agent blocks the request and returns a message such as "You don't have access to view the salary."



Checkpoint: A manager can view salary information; a general user is denied. Role-based access is enforced end to end.

7 Lab Reference Materials (for instructor)

- Getting started with watsonx Orchestrate ADK: https://developer.ibm.com/tutorials/getting-started-with-watsonx-orchestrate/
- OAuth2 On-Behalf-Of (OBO) flow in watsonx Orchestrate: https://www.ibm.com/docs/en/watsonx/watson-orchestrate/base?topic=applications-oauth2-behalf-flow
- IBM watsonx Orchestrate: https://www.ibm.com/products/watsonx-orchestrate/
- Role-based access control (RBAC): https://www.ibm.com/think/topics/rbac
- Model Context Protocol (MCP): https://www.ibm.com/think/topics/model-context-protocol
- Agentic AI: https://www.ibm.com/think/topics/agentic-ai
- IBM Bob home: https://bob.ibm.com
- Bob documentation: https://bob.ibm.com/docs/ide) |
- Bob QuickStart tutorial :https://bob.ibm.com/docs/ide/getting-started/quickstart/
- Bob skills: https://developer.watson-orchestrate.ibm.com/agents/agent_design/wxo_skills
- Build agentic workflows on watsonx Orchestrate using Bob https://developer.ibm.com/tutorials/build-programmatic-agentic-workflows-watsonx-orchestrate-bob/
- Build agents & MCP tools using Bob: https://developer.ibm.com/tutorials/build-agents-mcp-tools-watsonx-orchestrate-using-bob/
- BPMN to agents with Bob skills: https://developer.ibm.com/tutorials/bpmn-to-agents-bob-skills-watsonx-orchestrate/